

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Resource 04

AI Vendor Due Diligence Checklist

Evaluating Third-Party AI Features and AI-Enabled Vendors

NIST AI RMF 1.0 | EU AI Act Art. 26

Resource ID	TSEC-AI-04
Category	AI Governance
Framework Alignment	NIST AI RMF 1.0 (third-party risk); EU AI Act Article 26 deployer obligations
Version	1.1
Published	July 2026
Intended Audience	Procurement, Vendor Risk Management, CISOs, Compliance Officers
Prepared By	TSEC Risk & Cyber Advisory LLC
Classification	Public — For Educational & Advisory Use

TSEC Compliance Resource Library — www.tsecgrc.com/resources

Table of Contents

Table of Contents.....	2
Executive Summary	3
Vendor Assessment Overview	3
Before You Start: Tiering	3
Why AI Vendor Risk Is Different	4
Security Review	5
Privacy Review	5
AI Governance Review	5
Compliance Review	6
Sample Vendor Questionnaire	7
Security	7
Privacy & Data Use	7
AI Governance	7
Compliance	7
Evidence Checklist.....	8
Contract Clause Checklist.....	8
Ongoing Monitoring After Onboarding.....	9
Red Flags Quick Reference	9
Risk Rating	10
Common Pitfalls.....	10
Next Steps	11
Glossary of Key Terms.....	11
About TSEC & Next Steps	11

Executive Summary

Most organizations encounter AI risk first through vendors, not through models they build themselves. A CRM adds a generative AI writing assistant, an HR platform adds AI-powered resume screening, a monitoring tool adds an AI-driven alert triage feature — and each of these introduces AI-specific risk into the organization through a channel that standard vendor security questionnaires were not designed to catch.

This checklist extends existing third-party risk management with the questions and evidence requirements specific to AI. It reflects the direction of both regulatory guidance — the EU AI Act’s Article 26 requires deployers to verify vendor compliance rather than accept vendor claims at face value — and financial-sector guidance, including the U.S. Treasury’s AI risk management expectations for financial institutions, which call for independently verifiable evidence over vendor-supplied assurances alone.

Not Every Vendor Needs the Same Scrutiny

Tier your AI vendor population by impact rather than applying uniform depth of review to every vendor with an AI feature.

Reserve enhanced due diligence for vendors whose AI directly affects credit decisions, fraud determinations, compliance screening, hiring, healthcare, or customer communications.

A lightweight review is appropriate for low-sensitivity productivity features (e.g., AI-assisted scheduling or meeting summarization).

Vendor Assessment Overview

A complete AI vendor assessment covers five areas: security, privacy, AI governance, regulatory compliance, and an overall risk rating that determines the level of ongoing monitoring required. Each section below lists the core questions to ask and the evidence to request — vendor marketing claims should be treated as a starting point, not a substitute for documentation.

Before You Start: Tiering

Tier	Criteria	Review Depth
Tier 1 — Critical	AI directly affects credit, fraud, compliance screening, hiring, healthcare, or customer-facing financial decisions	Full assessment (all sections below), legal review, annual reassessment
Tier 2 — Significant	AI processes sensitive data or materially influences (but does not solely determine) a business decision	Full assessment, lighter legal review, reassessment on contract renewal
Tier 3 — Limited	AI feature is internal-facing, low-sensitivity, and does not process regulated data categories	Security and privacy review only

Why AI Vendor Risk Is Different

Traditional vendor risk management assumes a relatively static product: the vendor's security posture today is a reasonable predictor of tomorrow. AI features break that assumption in three ways. First, the underlying model can change without a corresponding product release — a vendor may swap foundation-model providers with little notice, altering behavior and risk profile overnight. Second, data flows are less visible: a prompt or document a user submits may pass through one or more sub-processor AI providers the primary vendor does not prominently disclose. Third, AI-specific failure modes (bias, hallucination, prompt injection) are not covered by a general SOC 2 or ISO 27001 audit, which were designed before these risks existed as a category. Due diligence has to account for all three.

Security Review

- ☐ The vendor can describe, in writing, what underlying model(s) power the AI feature — including any sub-processor AI providers.
- ☐ The vendor has performed security testing specific to the AI feature (e.g., prompt injection resistance, output sanitization) — a general SOC 2 or ISO 27001 certification alone does not cover this.
- ☐ The vendor documents how the AI feature is isolated from other tenants in a multi-tenant environment (no cross-customer data leakage through shared model context).
- ☐ Access controls, logging, and monitoring for the AI feature meet the same bar as the vendor's core platform.
- ☐ The vendor has an incident notification process that explicitly covers AI-specific incidents (data leakage through model output, biased or harmful output reaching customers).

Privacy Review

- ☐ The vendor states clearly, in contract language rather than marketing copy, whether customer data or prompts are used to train or fine-tune its models.
- ☐ If customer data is used for model improvement, an opt-out (or opt-in) mechanism exists and is documented.
- ☐ The vendor documents data residency, retention, and deletion practices specific to AI-processed data (prompts, outputs, logs), which may differ from its general data retention policy.
- ☐ Sub-processor AI providers (e.g., a third-party foundation model vendor) are disclosed, and their data handling terms are consistent with the primary vendor's commitments.
- ☐ The vendor supports data subject requests (access, deletion, correction) that touch AI-processed data, not only data in its primary database.

AI Governance Review

This section evaluates whether the vendor runs its own AI program responsibly — a strong signal of how the AI feature will behave in production and how the vendor will respond when something goes wrong.

- ☐ The vendor can describe its internal AI governance structure (an accountable owner, a review process for new AI features) rather than treating AI governance as purely a compliance-marketing exercise.

- ☐ The vendor tests its models for bias and disparate impact where the feature affects decisions about individuals, and can share a summary of results or methodology.
- ☐ The vendor has a defined process for evaluating and communicating model version changes (e.g., swapping the underlying foundation model), including advance notice to customers when a change could materially affect output behavior.
- ☐ The vendor maintains human-review or override capability for AI-driven decisions that materially affect customers, rather than fully automating consequential outcomes.
- ☐ The vendor holds or is pursuing relevant certifications (ISO/IEC 42001, SOC 2 with AI-specific trust criteria) proportional to the criticality of the feature.

Compliance Review

- ☐ The vendor can identify which regulatory frameworks its AI feature is designed to support compliance with (e.g., EU AI Act transparency obligations, sector-specific rules), rather than disclaiming all regulatory responsibility to the customer.
- ☐ Where the AI feature could contribute to a "high-risk" classification under the EU AI Act or an equivalent state law, the vendor provides documentation the deployer needs to meet its own conformity and disclosure obligations.
- ☐ Contract terms allocate responsibility clearly between vendor and customer for AI-related compliance failures — silence in the contract should be treated as a red flag, not an acceptable default.
- ☐ The vendor provides audit rights or independently verifiable evidence (not only self-attestation) for Tier 1 critical vendors, consistent with regulatory expectations that deployers verify rather than assume vendor compliance.

Sample Vendor Questionnaire

Use the questions below verbatim or adapt them for a formal RFP or security questionnaire process. They are organized by the same five review areas and are written to elicit specific, verifiable answers rather than yes/no marketing responses.

Security

1. Describe the underlying model(s) powering this feature, including any third-party or sub-processor AI providers.
2. What security testing has been performed specifically against this AI feature (e.g., prompt injection, adversarial input testing)? Please share a summary or attestation.
3. How is tenant data isolated within the AI feature in a multi-tenant environment?
4. What is your process and SLA for notifying customers of an AI-specific security incident?

Privacy & Data Use

5. Is customer data or prompt content used to train or fine-tune your models? If yes, under what terms, and is an opt-out available?
6. Where is data processed and stored for this AI feature, and does this differ from your platform's standard data residency?
7. What is your data retention and deletion policy for prompts, outputs, and related logs?
8. Which sub-processors (including AI/model providers) have access to customer data through this feature?

AI Governance

9. Who owns AI risk decisions within your organization, and what does your internal AI review process look like?
10. Have you tested this feature for bias or disparate impact? Please share methodology and results if the feature influences decisions about individuals.
11. What is your process for evaluating and communicating changes to the underlying model?
12. Do you hold, or are you pursuing, ISO/IEC 42001 or equivalent AI management system certification?

Compliance

13. Which regulatory frameworks (EU AI Act, state AI laws, sector-specific guidance) does this feature help our organization comply with, and where does responsibility remain with us as the deployer?

14. Can you provide documentation needed to support our own conformity or disclosure obligations if this feature is used in a high-risk context?
15. What audit rights or independently verifiable evidence can you provide beyond self-attestation?

Evidence Checklist

Requesting the right documents up front shortens the review cycle and reduces back-and-forth with the vendor. For Tier 1 and Tier 2 vendors, request the following before scheduling a review call:

- ☐ Model and architecture summary, including any third-party or sub-processor models used.
- ☐ Most recent security assessment or penetration test results covering the AI feature specifically (not only the core platform).
- ☐ Data flow diagram showing where prompts, uploaded content, and outputs are processed and stored.
- ☐ Written policy on use of customer data for model training or fine-tuning, including opt-out mechanics if applicable.
- ☐ Bias, fairness, or accuracy testing summary for any feature that influences a decision about an individual.
- ☐ Incident history or disclosure record for AI-specific incidents in the past 12–24 months.
- ☐ Applicable certifications (SOC 2, ISO 27001, ISO/IEC 42001) and their scope — confirm the AI feature is actually inside the certified boundary, not adjacent to it.
- ☐ Standard contract language covering AI-specific data use, liability, and change-notification terms.

If a vendor cannot produce several of these items for a Tier 1 use case, treat that gap itself as a finding — the inability to document AI risk management is informative even before any single control failure is identified.

Contract Clause Checklist

Standard vendor contracts rarely address AI-specific terms unless explicitly negotiated. For Tier 1 and Tier 2 vendors, confirm the contract (or an addendum) includes:

- ☐ A clear statement on whether customer data may be used to train or improve the vendor's models, and under what consent or opt-out mechanism.
- ☐ Advance notice requirements for material changes to the underlying model or AI feature that could affect output behavior or risk profile.

- ☐ Audit rights or a commitment to provide independently verifiable evidence of AI risk management practices, proportional to the vendor's tier.
- ☐ Liability allocation for harm arising from AI-generated errors, biased output, or a security incident involving the AI feature.
- ☐ Data deletion and return obligations that explicitly cover AI-specific artifacts (prompts, embeddings, fine-tuned model weights derived from customer data) upon contract termination.
- ☐ Sub-processor disclosure and flow-down requirements ensuring any AI sub-processor is bound by equivalent data protection terms.

Ongoing Monitoring After Onboarding

Due diligence does not end at contract signature — AI vendor risk requires active monitoring proportional to tier, since the vendor's model and practices can change after the review is complete.

- ☐ Tier 1 vendors are reassessed on a fixed annual cadence regardless of contract renewal timing.
- ☐ Vendor-issued release notes and model change announcements are reviewed for AI-relevant changes as they are published, not only at renewal.
- ☐ A designated owner tracks open remediation commitments from prior assessments through to closure.
- ☐ Vendor AI incidents reported in the broader market (news, security advisories) are checked against the organization's vendor inventory even outside the vendor's own disclosure.

Red Flags Quick Reference

Use this quick-reference list during vendor calls or when reviewing questionnaire responses. Any single item below warrants a follow-up question before proceeding; two or more on a Tier 1 vendor warrants escalation.

- ☐ The vendor cannot name the specific underlying model(s) powering its AI feature.
- ☐ The vendor's answer to "do you use our data to train your models" is vague, marketing-worded, or inconsistent across contract, questionnaire, and sales conversations.
- ☐ The vendor treats a general SOC 2 or ISO 27001 certification as sufficient evidence of AI-specific security testing.

- ☐ The vendor cannot describe how it tests for bias or disparate impact on a feature that influences decisions about individuals.
- ☐ The vendor resists including AI-specific terms (data use, change notification, audit rights) in the contract.
- ☐ The vendor has had a publicly reported AI-related incident it did not proactively disclose to customers.

Risk Rating

Combine findings from the four review areas into an overall vendor risk rating and a defined reassessment cadence.

Rating	Description	Reassessment Cadence
Low	No material gaps identified across security, privacy, governance, and compliance review.	Contract renewal
Moderate	Minor gaps identified with a documented remediation plan and vendor commitment to timeline.	Annually
High	Material gaps in one or more areas (e.g., undocumented data use for model training, no bias testing for a decisioning feature).	Semi-annually, with executive visibility
Unacceptable	Vendor cannot or will not provide evidence for Tier 1 critical use cases.	Do not proceed until resolved

Document the overall rating, the specific findings that drove it, and the accountable owner for tracking any remediation commitments through to closure.

Common Pitfalls

16. Applying the standard security questionnaire and assuming it covers AI risk, when most legacy questionnaires predate generative AI entirely.
17. Accepting a vendor's marketing claim ("we take AI safety seriously") in place of specific, verifiable evidence.
18. Reviewing the AI feature once at contract signature and never revisiting it, even as the underlying model changes.
19. Failing to tier vendors by impact, which either over-invests scrutiny in low-risk tools or under-invests in Critical ones.

Next Steps

Vendors rated High or Unacceptable on Tier 1 or Tier 2 use cases should be escalated through the organization's standard vendor risk exception process before contract signature or renewal. Findings from this checklist should also feed the organization's broader AI system inventory and risk register — see TSEC's AI Governance Readiness Checklist and AI Risk Assessment Checklist for how vendor findings connect to the organization's overall AI governance program.

Glossary of Key Terms

Term	Definition
Sub-Processor	A third party engaged by a vendor to process data on the vendor's behalf, including third-party foundation model providers.
Tiering	Categorizing vendors by risk/impact to determine the appropriate depth of due diligence.
Flow-Down Requirement	A contract term requiring a vendor's sub-processors to be bound by equivalent data protection obligations.
Model Change Notification	A vendor's commitment to inform customers before materially changing the underlying AI model powering a feature.
Self-Attestation	A vendor's own unverified claim about its practices, as distinct from independently verifiable evidence.

About TSEC & Next Steps

TSEC Risk & Cyber Advisory LLC helps SMBs, SaaS companies, FinTech, healthcare organizations, professional services firms, manufacturers, and government contractors build governance, risk management, and compliance programs that hold up under audit — and under real-world adversarial conditions. Our advisory work spans SOC 2, ISO 27001, NIST CSF, HIPAA, PCI DSS, NYDFS, and emerging AI governance requirements.

This resource is one part of a broader compliance library. Organizations that need help translating a checklist into an operating program — policies, control ownership, evidence collection, board reporting, and audit readiness — typically engage TSEC for structured advisory support rather than building it alone.

Work With TSEC

Book a Strategy Call — a working session to review your current AI governance posture against NIST AI RMF and ISO/IEC 42001, and identify the highest-priority gaps.

Email: Info@tsecgrc.com

Web: www.tsecgrc.com

Visit www.tsecgrc.com/resources for the full compliance resource library

© 2026 TSEC Risk & Cyber Advisory LLC. This resource is provided for general informational and educational purposes and does not constitute legal advice. Organizations should consult qualified legal counsel to assess specific regulatory obligations.